

Product Cybersecurity Threat Analysis and Risk Assessment



Schmidt, Matthias
Director Global Security Services Product Security

Veröffentlicht 7/14/2026

Goal

Threat Analysis and Risk Assessment (TARA) is the overall fundamental activity to identify and address Cybersecurity Threats and risks in a "System under consideration".

This Page describes the overall procedure to perform a TARA. Provides guidance for the needed information about the product, system or solution. Further, this Page describes the process for performing a TARA and subsequent steps. This Guidance uses the Microsoft Threat Modelling Tool with a dedicated template for Industrial environments and products.

Before starting to model your System, you have to pre-describe your "System under consideration" (SUC). This description is needed to have a clear understanding what we have to investigate, what are environmental and functional pre-requirements and restrictions.

Setting the System under consideration (SUC)

Clear identification and description of the system

The basis of the threat analysis is the clear description of the system and its limits. The following information must be available:

- Description of the system
 - Overview Architecture
 - Overview of interfaces (internal and external) and the available communication protocols

- Classification of the System under considerations
 - Determination of the scope of application and the target group
 - Intended use / reasonably foreseeable misuse
 - Device Type classification
 - Overview of critical resources and "assets"
 - Data classification
 - Memory classification
 - other non specific properties
 - Exposure Level
 - Definition of communication capabilities
 - Definition of protection objectives
 - Definition of Attackers and their motivation
 - Determination of lifecycle and the related users and other dependencies, based on customer journey
 - Determination of what is not part of the system
 - Setting the Trust Boundaries of the SUC

Determination of the limits of low-voltage equipment

In accordance with the requirements of CENELEC Guide 32 (1st edition, 2014-07), the following basic assumptions (Section 5) are made and taken into account for the IT security-relevant risk assessment.

- The low-voltage equipment considered in this risk assessment is intended for use in a safe environment in accordance with IEC EN 62443-1-1.
- The user must carry out a risk assessment for the use of the low-voltage equipment corresponding to the use
- As part of a system, a low-voltage equipment cannot provide all the protections against IT security-related risks at the product level.
- For the proper functioning of IT security-relevant functions, measures must be taken on the system side and functions must be provided.
- The user must take measures that ensure the physical protection of the low-voltage equipment based on the risk analysis

Classification of the SUC

- Determination of the scope of application and the target group
- Intended use / reasonably foreseeable misuse
- Device Type classification

Type	Description
Network Device	Devices whose main purpose is data transmission or data filtering, e.g. switches, VPN endpoints, firewalls (the devices are not directly involved in the control of the system)
Embedded Device	Industrial control (e.g. PLC), which is programmable. Also includes smart sensors and actuators that process measurement data. (Note: no accessible operating system, the hardware product manufacturer is responsible for updates)
Host Device	Workstation computers or servers in an industrial environment with standard operating systems (Windows, Linux, open operating systems, the operator keeps his system environment up to date). Also includes log servers
Software Application	Programs and the associated data (Note: the software usually runs on embedded devices or host devices)

- Overview of critical resources and "assets"

The following resources and assets must be documented and considered in the threat analysis. In a threat analysis, the term "assets" refers to any valuable assets that need to be protected. All resources whose compromise can have an impact on availability, integrity and confidentiality, or represent a business risk for the manufacturer, are worthy of protection. Resource and assets could be, for example:

- Data
 - Applications, such as web server applications
 - Databases
 - Intellectual property, software code worthy of protection
 - Access data, key material
- Data classification (optional)

Type	Description
System	General system data that is not related to a specific person or is not security-relevant. This type of data has no impact on the availability, integrity or confidentiality or impact on the safety of any person.
Sensitive system data	Data that is not related to a specific person and has no relevant impact on security, but with a significant potential for financial or other harm or impact on the user's security if the availability, integrity and confidentiality of the data is compromised. This includes, for example, confidential business information or recordings from surveillance cameras.
Personal	General data concerning a specific person without causing significant potential harm to the user if the availability, integrity and confidentiality of the data is compromised. This includes, for example, names and public photos.
Sensitive personal data	Data that concerns a specific person and that causes significant potential harm to the user if the availability, integrity and confidentiality of the data is compromised. This includes health data, private messages, and personal financial information
Security	Security-related data that is not related to a specific person, but with significant security implications if the availability, integrity, and confidentiality of the data is compromised. This includes, for example, passwords, security-critical configuration
Sensitive security data	Security-related data unrelated to a specific person, but with significant implications for the security of the TOE and other products if the integrity and confidentiality of the data is compromised. These include, for example, master keys
Customer data	

- Memory classification

Volatility documents document the locations for volatile and non-volatile data in a hardware device. This information is necessary to protect devices when they are removed for repair, reallocation, or disposal to

ensure that data is not inadvertently made available to other people. In accordance with the requirements of NIST SP800-88r1 (Guidelines for Media Sanitization, NIST 800-88), appropriate measures are necessary for the secure deletion of data/information.

Volatility documents include the following sections:

- Modules Covered – Product variants to which the volatility document applies.
- Volatile Memory – Locations for data lost when turned off and on.
- Non-volatile memory – Locations for data that are retained even when power is turned off and on.

The memory lists include information about whether the storage location has a battery backup and whether it is user- and system-accessible. The lists also include a description of the deletion process for each location. Deletion instructions are documented as procedures. Procedures can be physical actions such as disconnecting a backup battery. A procedure can consist of a series of function calls that can be used to delete the data.

- other non specific properties

Communication over insecure networks (zone transition)	Insecure networks are usually topologies that are not the responsibility of the component manufacturer, integrator or operator. This includes mobile phone connections and other wireless connections that are not the administrative responsibility of the operator. Furthermore, this includes all connections provided by service providers.
Users in the life cycle of the system	When looking at the lifecycle, all users who interact with the system must be recorded and associated access rights must be determined. The aim of this provision is to reduce the impact on the availability and integrity of the system due to incorrect operation by operating personnel. An overview of operating personnel can be found in IEC IEC 62351-8.
Data persistence on the system	In addition to parameter and configuration data, it should be determined whether customer data is stored on the system. Based on the respective phases of the life cycle, separate requirements must be determined.

- Exposure Level

After the system has been determined and described, the position (exposure) is determined.

Type	Description
Zone Level 4: Enterprise / Intranet of the operator	This zone describes the office IT environment of the operator including the transition to the ISP network or Internet access. User endpoints and central instances (servers, virtual and physical) are operated in this zone. The systems are subject to regular updating and short operating times (user terminals ≤ 4 years). Program updates are also the rule here, usually within the framework of 2 years. The main protection goal of this layer is the confidentiality of information. This is followed by integrity and concludes with availability. The background to this is the high data density and mostly business-critical information and customer data. Availability is rated lower because critical systems are usually designed redundantly and the availability of workstation systems can be intercepted by shifting the activity to other wards. The environment is usually divided and segmented across the organization. These include closed office workstations as well as comprehensive access restrictions at the file and information level. The systems in the enterprise level are usually connected to the Internet and access to web resources is one of the regular activities of the employees. In smaller environments, regular updates are carried out automatically by the systems directly from the Internet.
Zone Level 3: OT network of the operator	This subcategory describes a network section (can contain several segments) for production-related IT systems. The OT network is separated from the IT network by network-side solutions. The transition from IT to OT determines the change in protection goals from CIA (Confidentiality-Integrity-Availability) to AIC (Availability-Integrity-Confidentiality). The systems at this level are indirectly directly linked to the value creation of the company. Failures at this level usually have a direct impact on production processes. The runtime of the central OT systems is longer than at level 4 and regular updates of the operating environment are carried out rather rarely and are associated with high effort and costs. A direct internet connection is usually not available. Updating the systems in the OT network is usually carried out

Type	Description
	manually within the framework of scheduled maintenance windows. The systems in the OT network may be restricted or accessible. Production-related systems are accessible and can be operated by changing personnel.
Zone Level 2: Production or machine network of the operator	A segment of the OT network that contains a part of the value chain or covers a sum of processes. Components within a Zone Level 2 have the same protection objective. Zone 2 groups together systems of a production line or area. This level provides remote maintenance access for machine manufacturers. In addition, systems of a machine are grouped together in this level. This segmentation is usually distinguished from other systems by micro-segregation firewall systems.
Zone Level 1: Fieldbus level (below the production network)	At the fieldbus level, all components that are connected exclusively via fieldbuses are combined. Systems at Level 1 communicate via proprietary protocols. The main characteristic of this communication is a fast or deterministic runtime. The availability of the transmitted data is a fundamental component of these systems.

All levels shown here are delimited by "Trust Boundaries". All systems within a zone should have the same security requirements, respectively provide.

- Definition of communication capabilities

The intended use can determine the ability to communicate and the accessibility. This results in requirements for the strength of the protective measures provided and the necessary measures for access protection and the necessary communication.

- Component can be accessed directly from the operator network or from another zone with different security requirements

Components offer interfaces for incoming connections that are to be reached across zone boundaries. This includes published resources such as web or medium servers, ERP systems that must be accessible from the OT network, and VPN endpoints.

- Component has direct access to the Internet. Applies in conjunction with other classifications

Components can directly access resources that are outside of the customer's administrative responsibility. This includes, for example, components that connect PaaS or SaaS cloud solutions or carry out updates independently. The challenge here is that no malicious code can be loaded and executed and that sensitive data of all kinds is protected.

- Component/cabling is not accessible via the operator's network (Level 4). Access to external interfaces (USB, user interface) possible)
 - Component communicates with other components in the operator network
 - Component is not accessible via the operator network, but access to external interfaces (USB, user interface) is possible.
 - The component is not accessible from the outside via the network and is protected from unauthorized access in the machine.
- Definition of protection objectives
 - Definition of Attackers and their motivation

Type	Definition
Script kiddies	These attackers use pre-built scripts or tools developed by others to exploit vulnerabilities in systems. They often have only basic knowledge and little motivation, but they can still cause damage.
Casual attackers	People who happen to encounter a vulnerability and exploit it without having specific knowledge or resources. Their attacks are often opportunistic and untargeted.
Insiders with limited knowledge	Employees or people within an organization who have access to internal systems but have limited technical knowledge. They could act out of dissatisfaction or curiosity. Employees or individuals with access to internal systems can intentionally or unintentionally cause security breaches. This can happen through dissatisfaction, financial incentives, or simply human error
Hacktivists	Activists who act for ideological reasons and often use simple methods to spread their

Type	Definition
	messages or draw attention to their causes. Their resources and technical skills may vary, but they often use easily accessible tools. These groups carry out attacks for ideological reasons, to draw attention to certain issues or to exert political pressure. They often use simple methods to achieve maximum impact
Low-budget cybercriminals	Criminals who use low-cost or free tools and techniques to gain financial gain. They could use phishing attacks, simple malware, or social engineering
State-backed actors	Nation-states or state-backed groups carry out targeted attacks on critical infrastructure to gain political or economic advantage. These attacks are often very sophisticated and difficult to detect
Terrorists	Terrorist groups could attack OT systems to cause chaos or disrupt critical infrastructure. Such attacks can have a significant impact on public safety and the economy
Advanced Persistent Threats (APTs)	These are sophisticated, long-term attacks that are often carried out by state-sponsored groups. They aim to penetrate a network and remain undetected in order to collect information or cause disruption over a longer period of time

- Determination of lifecycle and the related users and other dependencies, based on customer journey

When selecting the necessary cyber security protection functions, the following life phases and tasks according to CENELEC Guideline 32 are taken into account:

- Commissioning
 - Attitude
 - Examination
 - Programming
 - Hit
- Use
 - All operating modes

- Troubleshooting/Troubleshooting
- planned maintenance and repair
- Unplanned maintenance and repair
- System security threats (communication, access routes)
- reasonably foreseeable misuse
- Decommissioning, dismantling and disposal, as far as safety is concerned
 - Removal of the product from the low-voltage equipment
- Determination of what is not part of the system
- Setting the Trust Boundaries of the SUC

The trust boundaries of a "system under consideration" determine the different areas of responsibility, the level of trust and at the same time the threats that can be considered within the scope of what is possible. A trust boundary marks the point at which the level of trust between different system components changes. At the beginning of the threat analysis, the necessary trust limits must be determined.

Documentation

All information on the determination of the component must be included in the technical documentation.

The information becomes the basis for all Cybersecurity-relevant information for the system integrator or the end customer.

Guideline: Nutzung des Microsoft Threat Modeling Tools

1. Ziel und Anwendungsbereich

Diese Guideline beschreibt, wie das **Microsoft Threat Modeling Tool (TMT)** genutzt wird, um Bedrohungsmodelle für Produkte zu erstellen.

Zielgruppe: Entwickler, Architekten, Security-Experten.

2. Voraussetzungen

- Installation des Tools: [Download-Link](#)
 - Grundkenntnisse in:
 - Softwarearchitektur
 - **STRIDE-Methode** (Spoofing, Tampering, Repudiation, Information Disclosure, Denial of Service, Elevation of Privilege)
-

3. Schritt-für-Schritt-Anleitung

3.1 Neues Modell erstellen

- Öffne das Tool und wähle unterhalb der Kachel **Create A Model** das zu verwendene Template `iem_automation.tb7` aus. Anschließend klicke auf die Kachel **Create A Model**.
- Vergib einen aussagekräftigen Namen und eine Beschreibung des betrachteten Systems in den Modelleigenschaften (File -> Threat Model Information).
 - **Tipp:** Sei präzise in der Festlegung, was zum System gehört. Mach auch explizit, was nicht dazu gehört. Dies ist wichtig, um insbesondere auch zukünftig noch nachvollziehen zu können, was bereits betrachtet wurde und was ausgespart wurde.

3.2 Datenflussdiagramm (DFD) anlegen

- Füge die folgenden Elemente hinzu:
 - **External Entities**
 - **Processes**
 - **Data Stores**
 - **Data Flows**
 - **Trust Boundaries**
- Ergänze **Assets** und **Schutzziele** als Notizen (Notes Tab am unteren Fensterrand)

- Ordne alternativ/zusätzlich **Assets** als Custom Attribute den Diagrammelementen zu.
 - Beispielsweise als "Asset: Credentials"
- Ergänze den **Security Context** und Annahmen in den Modelleigenschaften (File -> Threat Model Information).
 - Der *Security Context* ist essenziell für die spätere Risikobewertung und wird typischerweise iterativ angepasst. Des Weiteren bestimmt dies, wie detailliert das Modell benötigt wird.
- **Tipp:** Beginne mit einem groben Überblick und verfeinere schrittweise. Für die Verfeinerung von Elementen, können auch neue Diagramme angelegt werden (Diagram -> Add New Diagram). Dies kann die Übersichtlichkeit der Diagramme erhöhen und werden vom TMT für die Analyse separat betrachtet.

3.3 Bedrohungsanalyse durchführen

- Klicke auf **Switch To Analysis View**.
- Das Tool generiert automatisch Bedrohungen basierend auf STRIDE und dem hinterlegten Template.
 - Im **Victim**-Feld sollte das Opfer der Bedrohung eingetragen sein, d.h. das Ende des Data Flows, das von der Bedrohung betroffen ist. Diese Info hilft oft beim Verständnis der Bedrohung.
 - Im **Possible Countermeasures**-Feld stehen mögliche/typische Gegenmaßnahmen. Diese Info hilft, zu verstehen welche Gegenmaßnahmen die Bedrohung abschwächen könnten und sich für eine Gegenmaßnahme zu entscheiden.
 - Das Feld **IEC 62443 CRs/CR-REs** enthält eine Liste der für die Bedrohung relevanten Component Requirements und Requirement Enhancements aus der IEC 62443-4-2. Auch diese Info soll helfen, Gegenmaßnahmen zu wählen. Die Liste ist *nicht vollständig* und die gelisteten CRs müssen auch *nicht alle* umgesetzt werden.
- Überprüfe die Liste:
 - Markiere irrelevante Bedrohungen als **Not Applicable**. Das Tool macht Bedrohungsvorschläge basierend auf den im Template hinterlegten Regeln, es ist nicht allwissend.
 - Ergänze im Feld **Justification** eine Erklärung, warum die Bedrohung relevant oder nicht relevant ist.
 - Beschreibe vorhandene oder geplante Gegenmaßnahmen im Feld **Chosen Countermeasures** und wähle einen passenden **Status**.
 - Bewerte das Risiko jeder relevanten Bedrohung mittels der Eigenschaften **Likelihood** und **Impact**. Der Wert für das Feld **Risk** bestimmt sich aus den zuvor festgelegten Werten für *Likelihood* und

bestimmen sich aus den zuvor festgelegten Threats, Assets und

Impact. Beachte, dass das **Risk** nicht automatisch ausgewählt wird, sondern manuell anhand der verwendeten Risikomatrix belegt werden muss.

- Ergänze manuell weitere spezifische Bedrohungen, welche noch nicht vom TMT generiert wurden. Klicke dazu mittels Rechtsklick auf den Diagrammhintergrund -> **Add User-defined Threat**.

3.4 Ergebnis exportieren

- Speichere das Modell (als .tm7).
- Exportiere das Modell über das Reports-Menü als HTML **Threat Report**. Dann wird auch das Diagramm mitexportiert.
- Alternativ kann auch nur die Bedrohungsliste über den Button **Export Csv** (unterhalb der Bedrohungsliste) als .csv exportiert und danach z.B. in Excel geöffnet werden.
- Integriere den Bericht in die Projekt-Dokumentation oder Compliance-Nachweise.

4. Best Practices

- **Früh starten:** Threat Modeling in der Designphase durchführen.
- **Iterativ arbeiten:** Modell regelmäßig aktualisieren, insbesondere bei Architekturänderungen.
- **Team einbeziehen:** Entwickler, Security und Architekten gemeinsam.
- **Standardisierte Namenskonventionen:** Schemata für Prozesse und Datenflüsse verwenden.

5. Typische Fehler vermeiden

- Zu detaillierte oder zu grobe Modelle.
 - Beachte den Security-Kontext und aggregiere Prozesse und Datenflüsse, bei denen sich die Bedrohungen nicht weiter unterscheiden (bspw., wenn Angriffe nur physisch möglich sind). Bewerte stattdessen das gemeinsame Risiko (bspw. des physischen Angriffs) und abstrahiere die Details.
- Bedrohungen ignorieren, die „unwahrscheinlich“ erscheinen.
- Keine Dokumentation der gewählten Gegenmaßnahmen.

6. Weiterführende Ressourcen

- [Microsoft-Dokumentation](#)

Subsequent steps

Integration of Findings in System-Specification

All identified risks are treated in accordance with the risk mitigation strategy.

- **Risk aversion**
The risks can be avoided by restructuring the information network in such a way that the threat can no longer become effective. This is a good idea, for example, if countermeasures are possible, but involve too much effort and at the same time the risk cannot be accepted.
- **Risk reduction** (risk modification) through further security measures
The risks can be reduced by additional, higher-quality security measures.
- **Risk transfer**
The risks are shifted. By taking out insurance or outsourcing the risky task to an external service provider, for example, a possible financial loss can be passed on (at least in part) to third parties.
- **Risk acceptance**
The risks can be accepted, either because the hazard could only lead to damage under extremely special conditions, because there are no sufficiently effective countermeasures known or because the effort required for possible protective measures is unreasonably high.

In the Overall TARA Documentation all Threats leads to a requirement in the system specification of the product. For a traceability of needed Cybersecurity requirements it is recommended to label all Cybersecurity related requirements.

The following Labels could be helpful:

security-func

Marks functions that have been identified based on the requirements for the product. This also includes the testing and validation tasks as part of the requirement

security-doc

Flags information that must be made available to the customer in connection with cybersecurity. These include, at least, if applicable:

- the intended purpose of the product with digital elements, including the security environment provided by the manufacturer, as well as the main functions of the product and information about the safety features

- any known or foreseeable circumstances related to the intended purpose of the product with digital elements or its reasonably foreseeable misuse that may lead to significant cybersecurity risks
- the type of technical security support offered by the manufacturer and the end date of the support period during which users can expect to fix vulnerabilities and receive security updates;
- detailed instructions or an internet address where such detailed instructions and information are referred to,
 - what measures must be taken during the initial commissioning and throughout the life of the product with digital elements to ensure its safe use,
 - how changes to the product with digital elements can affect data security,
 - how to install security-related updates,
 - how to safely decommission the product with digital elements and how user data can be safely removed;
 - how to disable the default setting that allows the automatic installation of security updates as set out in point (c) of Part I of Annex I;
 - how the integrator can comply with the essential cybersecurity requirements in Annex I and the technical documentation requirements in Annex VII if the product with digital elements is intended for integration with other products with digital elements;

no-security.

no-security means that an entry is not part of a cybersecurity-relevant function, nor does it represent a counter-measure - i.e. it is simply to be treated according to QM.

Identify Cybersecurity requirements for environment

When performing a TARA, there should be finding that are in the responsibility of the end customer or even the are requirements with a external dependency, e.g. System Time (NTP) or a remote Backup Storage destination. These external dependencies shall be document in the System specification and shall be content of the customer documentation.

Verantwortlich:



Schettgen, Dietmar

Vice President Global Security Services

Kontaktperson:



Schmidt, Matthias

Director Global Security Services Product Sec...



Startseite Produkt Cybersecurity